

Práctica 2D – Cross Site Scripting (XSS)

SEGUNDA PARTE

Seguridad en el Desarrollo de Aplicaciones

Alumna: Luz Celeste López Rivera

Docente: Gerardo Ramírez Villarreal

Objetivo

Analizar el comportamiento de una vulnerabilidad Cross Site Scripting (XSS) mediante la implementación de un módulo de comentarios que permita la ejecución de código JavaScript ingresado por el usuario.

Desarrollo

Se creó un módulo de comentarios dentro de la aplicación VulnerableApp. El formulario permite que cualquier usuario escriba comentarios y estos son mostrados posteriormente en la página.

La vulnerabilidad fue introducida utilizando `@Html.Raw(comment)`, lo que provoca que el contenido ingresado por el usuario sea interpretado directamente por el navegador como código HTML o JavaScript.

Después se realizaron pruebas ingresando comentarios legítimos y comentarios con código JavaScript para comprobar el comportamiento de la aplicación.

Pruebas realizadas:

1. Comentario legítimo: Se ingresó un comentario de texto normal "Hola, primer comentario"
2. Se ingresó el siguiente código: `<script>alert('XSS')</script>`, al enviar el comentario, el navegador ejecutó el script y mostró una ventana emergente con el mensaje "XSS".
3. El sistema mostró correctamente el contenido en pantalla: "Prueba XSS"

Análisis del riesgo

La vulnerabilidad ocurre porque la aplicación interpreta como código ejecutable la información proporcionada por el usuario.

Un atacante podría aprovechar esta situación para:

- Ejecutar código JavaScript en el navegador de otros usuarios.
- Robar cookies o identificadores de sesión.
- Modificar el contenido mostrado en la página.
- Redirigir usuarios a sitios maliciosos.
- Capturar información sensible.

La causa principal es la ausencia de validación de entrada y codificación segura de salida.

Conclusión

Durante la práctica fue posible reproducir exitosamente una vulnerabilidad XSS almacenada. Se comprobó que el navegador ejecuta código JavaScript cuando la aplicación muestra contenido utilizando `@Html.Raw()` sin realizar validaciones de seguridad. Este tipo de vulnerabilidad representa un riesgo importante para la confidencialidad e integridad de la información, por lo que debe mitigarse mediante validación de entradas y codificación adecuada de los datos mostrados al usuario.